

Autorização

QXD0011 - Fundamentos de Bancos de Dados

Universidade Federal do Ceará - *Campus* Quixadá

Prof. Francisco Victor da Silva Pinheiro
victorpinheiro@ufc.br



Agenda

- Autorização de Banco de Dados
- Onde ficam os privilégios?
- Obtenção de privilégios
- Autorização
- Especificação de Autorização em SQL
- Privilégios em SQL
- Revogação de Privilégios
- Revogação no PostgreSQL
- Outras características de Autorização
- Prática: Autorização e Controle de Privilégios no PostgreSQL

Autorização de Banco de Dados

- Em bancos de dados, autorização refere-se ao processo de conceder ou negar permissões a usuários, grupos ou sistemas para acessar e manipular dados e recursos específicos.
- É a etapa que determina o que um usuário autenticado pode ou não fazer com os dados armazenados.
- Garantir que usuários acessem somente o que podem realmente acessar.
- Preservar o banco de dados de modificações realizadas por usuários maliciosos.

Autorização de Banco de Dados

- **Autenticação:** Verifica a identidade do usuário que está tentando acessar o banco de dados.
- **Autorização:** Define quais operações o usuário autenticado tem permissão para realizar.
- **Permissões:** Regras específicas que concedem ou negam acesso a objetos de banco de dados (tabelas, views, etc.) ou operações (leitura, escrita, etc.).
- **Funções:** Grupos de permissões que podem ser atribuídos a usuários para simplificar o gerenciamento de acesso.
- **Controle de acesso:** Mecanismos para garantir que apenas usuários autorizados possam acessar dados e recursos específicos.

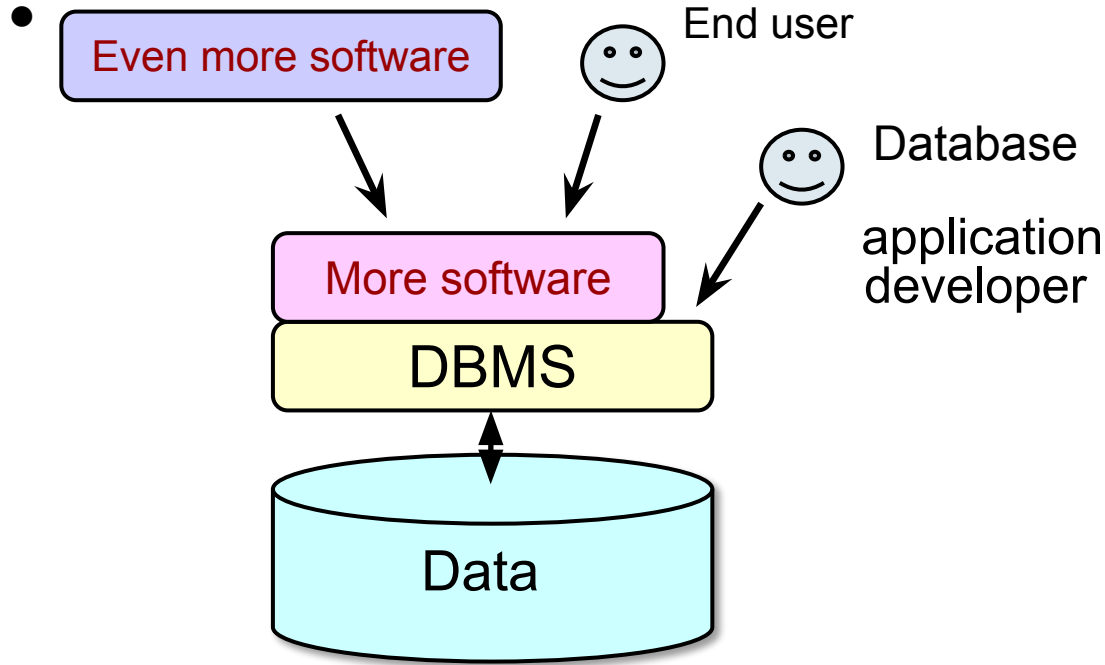
Exemplo

- Em um sistema de gerenciamento de banco de dados, um usuário pode ser autenticado como administrador, recebendo permissões para criar, modificar e excluir tabelas e dados.
- Outro usuário pode ser autenticado como um usuário comum, com permissão apenas para consultar e atualizar seus próprios dados.

Autorização de Banco de Dados

- Usuários possuem privilégios
- Somente podem operar sobre dados para os quais eles foram autorizados
 - Select on R or $\text{Select}(A1, \dots, A_n)$ on R
 - Insert on R or $\text{Insert}(A1, \dots, A_n)$ on R
 - Update on R or $\text{Update}(A1, \dots, A_n)$ on R
 - Delete on R
- Comandos Grant e Revoke
- Além dos privilégios a nível de tabelas
 - Use visões

Onde ficam os privilégios?



Obtenção de privilégios

- O criador da relação é o seu proprietário (owner).
- Ele tem todos os privilégios e pode conceder privilégios

Grant *privs* On **R** To
users
[With Grant Option]

Autorização

- **Formas de autorização em partes do BD:**
 - **Read** – permite leitura, mas não modificação dos dados.
 - **Insert** – permite inserção de novos dados, mas não modificação de dados existentes.
 - **Update** – permite modificação, mas não exclusão de dados.
 - **Delete** – permite exclusão de dados.

- **Formas de autorização para modificar o esquema do BD.**
 - **Index** – permite a criação e exclusão de índices.
 - **Resources** – permite a criação de novas relações.
 - **Alteration** – permite a adição e remoção de atributos em uma relação.
 - **Drop** – permite a remoção de relações.

Especificação de Autorização em SQL

- O comando grant é usado para dar autorização
 - grant <privilege list> on <relation name or view name> to <user list>
- <user list> é:
 - um user-id
 - public, permite concessão de privilégios a todos os usuários válidos
 - um papel (role)
- Conceder um privilégio a uma visão não implica concessão de privilégios às relações subjacentes.
- Quem concede o privilégio já deve ter privilégio sobre o item especificado ou ser o administrador do banco de dados.

Privilégios em SQL

- **select:** permite acesso de leitura à relação ou habilidade para consultar uma visão
- Exemplo:
 - Conceder autorização de select sobre a relação instrutor aos usuários U1, U2 and U3:
 - `grant select on instrutor to U1, U2, U3`

Privilégios em SQL

- **insert:** habilidade para inserir tuplas
- **update:** habilidade para atualizar usando o comando update da linguagem SQL.
- **delete:** habilidade para deletar tuplas.
- **all privileges:** forma compacta para todos os privilégios possíveis.

No PostgreSQL

```
CREATE USER joao WITH PASSWORD 'johnwayne';  
CREATE DATABASE scott;  
GRANT ALL ON DATABASE scott TO joao;  
ALTER USER joao PASSWORD 'tiger'  
  
-- Usuário atual  
SELECT USER;
```

No PostgreSQL

```
GRANT SELECT ON mytable TO PUBLIC;  
GRANT INSERT ON films TO PUBLIC;  
GRANT ALL PRIVILEGES ON kinds TO manuel;  
GRANT SELECT, UPDATE, INSERT ON mytable TO admin;  
GRANT SELECT (col1), UPDATE (col1) ON mytable TO miriam_rw;
```

Revogação de Privilégios

Revoke *privs* On *R* From *users*
[Cascade | Restrict]

- Cascade – também revoga privilégios concedidos a partir de privilégios sendo revogados (transitivamente), a menos que também tenham sido concedidos a partir de outra fonte.
- Restrict – desabilita a revogação através de cascade.

Revogação de Autorização em SQL

- O comando revoke é usado para revogar autorização.
 - revoke <privilege list> on <relation name or view name> from <user list>
- Exemplo: revoke select on branch from U1, U2, U3
- <privilege-list> pode ser all para revogar todos os privilégios do usuário.
- Se <user-list> incluir public, todos os usuários perdem o privilégio, exceto aqueles concedidos explicitamente.
- Todos os privilégios que dependem do privilégio revogado também são revogados.

Revogação no PostgreSQL

- REVOKE INSERT ON films FROM PUBLIC;
- REVOKE ALL PRIVILEGES ON kinds FROM manuel;
- REVOKE admin FROM joe;

Papéis (Roles)

create role instrutor; grant instrutor to Amit;

- Privilégios podem ser concedidos a papéis:
 - *grant select on takes to instrutor;*
- Papéis podem ser concedidos a usuários, como também a outros papéis:
 - *create role monitor*
 - *grant monitor to instrutor;*
 - Instrutor herda todos os privilégios de monitor
- Cadeia de papéis
create role dean; grant instrutor to dean; grant dean to Satoshi;

Papéis (Roles)

- No PostgreSQL
 - GRANT admin TO joe;
 - Role admin
 - User joe

Outras características de Autorização

- references dá privilégio para criação de chave estrangeira
 - *grant reference (dept_name) on department to Mariano;*
 - Para que pode ser usada?
- Transferência de privilégios
 - *grant select on department to Amit with grant option;*
 - *revoke select on department from Amit, Satoshi cascade;*
 - *revoke select on department from Amit, Satoshi restrict;*
- Etc.

Prática: Autorização e Controle de Privilégios no PostgreSQL

- No PostgreSQL (e na maioria dos SGBDs), a autorização consiste em definir quem pode fazer o quê no banco, garantindo segurança e controle de acesso.
- Os privilégios (permissões) são concedidos a usuários (roles) e podem ser concedidos ou revogados.

Criação de Usuários (Roles)

-- Conecte como superuser (postgres ou equivalente)

CREATE ROLE gerente LOGIN PASSWORD 'senha123';

CREATE ROLE analista LOGIN PASSWORD 'senha123';

CREATE ROLE estagiario LOGIN PASSWORD 'senha123';

CREATE ROLE auditor LOGIN PASSWORD 'senha123';

Onde Ficam os Privilégios?

- Privilégios ficam associados a objetos do banco (tabelas, views, sequências, funções, etc).
 - Podem ser consultados em tabelas do sistema:
 - `information_schema.table_privileges`
 - `pg_roles`, `pg_tables`, etc.
- *`SELECT * FROM information_schema.table_privileges WHERE grantee IN ('gerente', 'analista', 'estagiario', 'auditor');`*

Concessão de Privilégios

- -- **Concedendo privilégios ao gerente (acesso total)**
 - *GRANT ALL PRIVILEGES ON TABLE departamento, funcionario, projeto TO gerente;*
- -- **Analista: pode consultar, inserir e atualizar projetos e funcionários, mas não pode deletar**
 - *GRANT SELECT, INSERT, UPDATE ON funcionario, projeto TO analista;*
- -- **Estagiário: apenas pode consultar (SELECT) projetos**
 - *GRANT SELECT ON projeto TO estagiario;*
- -- **Auditor: pode consultar tudo, mas não modificar nada**
 - *GRANT SELECT ON ALL TABLES IN SCHEMA public TO auditor;*

Testando a Autorização

-- Como 'analista'

\c empresa analista

*SELECT * FROM funcionario; -- Deve funcionar*

DELETE FROM projeto WHERE Projnumero = 1; -- Deve dar erro de permissão

Testando a Autorização

-- Como 'estagiario'

\c empresa estagiario

*SELECT * FROM projeto; -- Deve funcionar*

INSERT INTO projeto VALUES ('Teste', 99, 'Sala 10', 1); -- Deve dar erro

Testando a Autorização

-- Como 'auditor'

\c empresa auditor

*SELECT * FROM departamento; -- Deve funcionar*

UPDATE funcionario SET Salario = 9999; -- Deve dar erro

Revogação de Privilégios

- REVOKE SELECT ON projeto FROM estagiario;
- -- Teste: tente SELECT como estagiario, deve dar erro de permissão
- Revogação em Cascata
 - Se um usuário recebeu privilégios e os repassou (com GRANT OPTION), ao revogar do usuário "pai", também remove dos "filhos".
- No PostgreSQL, use REVOKE ... CASCADE.
 - -- Exemplo (caso tenha usado GRANT OPTION):
 - -- REVOKE SELECT ON funcionario FROM analista CASCADE;

Bibliografia Básica

- ELMASRI, R.; NAVATHE, S. B. Sistemas de banco de dados. 6 ed. Pearson/Addison-Wesley, 2011. ISBN: 9788579360855
- SILBERSCHATZ, Abraham; KORTH, Henry F.; SUDARSHAN, S. Sistema de banco de dados. Rio de Janeiro: Elsevier: Campus, 2012. ISBN 9788535245356
- HEUSER, C. A. Projeto de banco de dados. 6 ed. Bookman, 2009. ISBN: 9788577803828



Obrigado!

Dúvidas?



Universidade Federal do Ceará - *Campus* Quixadá

Prof. Francisco Victor da Silva Pinheiro
victorpinheiro@ufc.br

